

Lumma Stealer / LummaC2

Windows Information Stealer and MaaS Ecosystem — Malware Analysis Report

Published: 2026-06-01 | TLP: CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Executive Summary

Lumma Stealer, commonly tracked as LummaC2, is a Windows-focused information stealer sold as malware-as-a-service. It has been active since at least 2022 and is used by financially motivated actors to steal browser credentials, session cookies, cryptocurrency wallet material, application data, local documents, host metadata, and other sensitive information. Microsoft tracks the developer and maintainer of the Lumma malware, C2 infrastructure, and MaaS ecosystem as Storm-2477.

Lumma should be treated as a high-severity intrusion even when the visible infection appears limited to one workstation. The primary business impact is not only local data theft. Stolen cookies, credentials, MFA-related artifacts, VPN profiles, email client data, FTP credentials, cloud session material, and cryptocurrency wallet data can enable account takeover, cloud compromise, business email compromise, financial fraud, initial access brokerage, and ransomware intrusion.

In May 2025, Microsoft, Europol, law enforcement, and industry partners announced a coordinated disruption of Lumma infrastructure. Microsoft reported identifying more than 394,000 globally infected Windows computers between March 16 and May 16, 2025, and the disruption targeted approximately 2,300 malicious domains associated with Lumma operations. This reduced active infrastructure capacity but should not be interpreted as eradication. Lumma's affiliate ecosystem, MaaS model, and rotating infrastructure make reconstitution and copycat activity plausible.

Key Judgments

Judgment	Confidence	Rationale
Lumma is primarily a credential, cookie, and session theft threat.	High	Microsoft, CISA/FBI, and MITRE all document browser and credential theft behavior.
Lumma incidents should be handled as identity compromise events.	High	Browser cookies, saved passwords, VPN profiles, and cloud sessions can remain useful after endpoint cleanup.
Static IOCs alone are insufficient for durable defense.	High	Lumma rotates domains, uses fallback C2 sources, and changes C2 protocol details across versions.
Lumma can support follow-on monetization beyond stealer activity.	Medium	Microsoft reports plugin and additional payload behavior, including clipboard theft and coin mining.
The 2025 disruption reduced infrastructure but did not remove the long-term threat.	Medium	Law enforcement disruption affected domains and services, but MaaS ecosystems commonly adapt.

2. Sample Metadata

This report is a public intelligence synthesis and does not analyze a single submitted binary sample. Malware behavior, infrastructure, and detection recommendations are based on public reporting from Microsoft, FBI/CISA, MITRE ATT&CK, and Europol.

Field	Value
Malware family	Lumma Stealer / LummaC2
Malware type	Information stealer, credential stealer, MaaS
Platform	Windows
Runtime / implementation	Microsoft reports C++ and assembly components with obfuscation and low-level API usage.
First observed	At least 2022, per public reporting.
Primary operator tracking	Storm-2477, per Microsoft.
MITRE ATT&CK software ID	S1213
Primary risk	Credential theft, session theft, data exfiltration, follow-on account takeover.
Sample-specific hashes	Not included; this report is not tied to a single sample set.
Scope note	Public reporting through 2026-06-01.

3. Source Review & Confidence

3.1 Evidence Ledger

Claim	Source	Source Date	Confidence	Notes
Lumma is a prolific infostealer with credential, cookie, wallet, and application data theft capabilities.	Microsoft Security Blog	2025-05-21	High	Detailed vendor technical analysis.
Microsoft observed more than 394,000 infected Windows computers between March 16 and May 16, 2025.	Microsoft On the Issues	2025-05-21	High	Stated during global disruption announcement.
Disruption targeted approximately 2,300 malicious domains associated with Lumma.	Microsoft On the Issues; Europol	2025-05-21	High	Law enforcement and industry action reporting.
LummaC2 has been used to exfiltrate sensitive data from organizations.	FBI/CISA AA25-141B	2025-05-21	High	Joint cybersecurity advisory.

Claim	Source	Source Date	Confidence	Notes
Lumma Stealer is tracked by MITRE ATT&CK as S1213.	MITRE ATT&CK	Current as of report date	High	Framework reference.
Lumma campaigns use phishing, malvertising, fake CAPTCHA / ClickFix, trojanized software, compromised websites, and loader malware.	Microsoft Security Blog; FBI/CISA AA25-141B	2025-05-21	High	Multiple source convergence.
Lumma can use fallback C2 references through services such as Telegram and Steam profiles.	Microsoft Security Blog	2025-05-21	Medium	Vendor analysis; specific implementation may vary by version.
Lumma has been used in campaigns involving ransomware actors.	Microsoft Security Blog	2025-05-21	Medium	Actor usage does not imply every infection leads to ransomware.

3.2 Confidence Assessment

Overall confidence is high for Lumma's role as a Windows infostealer, its MaaS model, credential theft capabilities, and broad social-engineering delivery patterns. Confidence is medium for version-specific C2 behaviors, plugin behavior, and affiliate-specific delivery details because these vary by campaign and can change quickly.

4. Payload Variants and Delivery

Lumma is affiliate-distributed, so delivery varies by campaign. The recurring theme is trusted-context abuse: victims believe they are interacting with a legitimate software download, verification prompt, email attachment, public repository, or well-known service.

Vector	Description	Defensive Concern
Phishing emails	Brand, invoice, hotel reservation, cancellation, subscription, or education-themed lures with malicious links or attachments.	Email controls must include URL rewriting, attachment analysis, user reporting, and post-delivery removal.

Vector	Description	Defensive Concern
Malvertising	Poisoned search ads for software-related searches such as browser updates, utilities, and productivity tools.	Users may trust sponsored or high-ranking search results.
Compromised websites	Injected JavaScript on legitimate sites redirects users to payloads, lures, or intermediary scripts.	Reputation-only blocking may miss compromised legitimate sites.
Fake CAPTCHA / ClickFix	Users are instructed to copy and run commands through Windows Run under the pretense of verification.	Creates suspicious RunMRU artifacts and living-off-the-land execution.
Trojanized software	Cracked, pirated, or spoofed installers execute Lumma while appearing useful.	Application control and unsigned binary blocking are critical.
Trusted platform abuse	GitHub or similar public services are abused to host scripts, binaries, redirects, or staging content.	Developer workflow trust can be exploited.
Loader malware	Other malware families, including loaders, may deploy Lumma as an additional payload.	Investigation should look for multi-payload compromise.

5. Infection Chain Analysis

The exact chain varies, but common Lumma intrusions follow this pattern:

- 1 User receives a lure or lands on a compromised, spoofed, or maliciously advertised page.
- 2 The lure causes download and execution of a payload, or instructs the user to run a command.
- 3 ClickFix-style chains place commands in the clipboard and instruct the user to paste into Windows Run.
- 4 The command may invoke `mshta`, `powershell`, `cmd`, `curl`, `iwr`, `irm`, JavaScript, or Base64-encoded content.
- 5 Intermediate scripts retrieve and execute Lumma, sometimes in memory or through staged loaders.

- 6 Lumma initializes, resolves C2, retrieves configuration, collects targeted data, and exfiltrates stolen content.
- 7 Depending on configuration, Lumma may retrieve plugin instructions or deploy additional malware.

FBI/CISA describes observed LummaC2 execution beginning with LummaC2 . exe entering a main routine with multiple subroutines. The advisory notes string decryption, user prompt behavior in analyzed samples, callback domain decryption, and HTTP POST requests to decoded C2 domains.

6. Technical Analysis

6.1 Family, Platform, and Runtime

Lumma is a Windows malware family. Microsoft describes the core malware as written in a combination of C++ and assembly and protected by multiple obfuscation layers. Reported protection and evasion characteristics include LLVM-based virtualization, control-flow flattening, control-flow obfuscation, stack decryption, dead code, low-level syscalls, and Heaven's Gate techniques.

6.2 Credential and Browser Theft

Lumma targets Chromium, Edge, Mozilla, and Gecko-based browsers. Data theft commonly includes saved passwords, session cookies, autofill data, browser extension data, payment-related browser data where available, and DPAPI-protected material accessible in the user's context.

Session cookies are especially high impact. In some environments, stolen cookies can allow a threat actor to bypass a password reset or MFA prompt until sessions are revoked, tokens expire, or conditional access controls block reuse.

6.3 Cryptocurrency Theft

Lumma searches for cryptocurrency wallet material, browser wallet extension data, and local keys. Microsoft references targets including MetaMask, Electrum, and Exodus. This creates immediate financial risk where infected users manage cryptocurrency assets.

6.4 Application and Document Theft

Observed target classes include VPN profiles, email client data, FTP client data, Telegram application data, user documents, and host metadata. Lumma may search common user directories for files such as . pdf, . docx, and . r t f, and collect system information including CPU data, operating system version, locale, and installed applications.

6.5 Loader Behavior

Lumma delivery may involve intermediate scripts, staged binaries, or loader malware. Microsoft reports that the Lumma loader may use process hollowing to inject into legitimate processes including msbui ld . exe, regasm . exe, regsvcs . exe, and exp l o r e r . exe. These host processes can appear benign at first glance, so process lineage and memory behavior matter.

6.6 Persistence

Public reporting emphasizes theft and exfiltration more than durable persistence. Many infostealer campaigns prioritize rapid execution, collection, exfiltration, and cleanup rather than long-term host

persistence. Analysts should still check common persistence locations because affiliate tradecraft can add scheduled tasks, Run keys, startup folder items, services, or secondary payloads.

6.7 Command and Control

Lumma C2 has evolved across versions. Microsoft identified multiple tracked versions with changes in domains, URI paths, POST formats, and C2 command patterns. Common traits include hardcoded tier 1 C2 domains, regularly updated C2 lists, fallback C2 pointers through Telegram and Steam profiles, Cloudflare-proxied infrastructure, and encrypted HTTPS communication.

Microsoft described parameters observed across versions, including `act`, `ver`, `lid`, `uid`, `j`, `cid`, `hwid`, and `pid`. Version-specific parameters change, so defenders should avoid relying only on fixed URI patterns.

6.8 Capabilities and Command Set

Known or reported capabilities include:

- Browser credential theft.
- Browser cookie and session theft.
- Browser autofill theft.
- Cryptocurrency wallet and extension theft.
- VPN, FTP, email client, Telegram, and document collection.
- Host profiling and system metadata collection.
- HTTP/HTTPS POST exfiltration.
- Dynamic configuration retrieval from C2.
- Plugin or secondary payload behavior in some observed campaigns.

7. Indicators of Compromise

7.1 Indicator Summary

This report intentionally emphasizes behavioral indicators over fixed public hashes or domains because Lumma infrastructure and payloads rotate quickly. Exact-match indicators should be obtained from current vendor feeds, EDR detections, sandbox submissions, and case-specific telemetry before production blocking.

Indicator Class	Count	Confidence	Recommended Use
SHA256 hashes	0 included	N/A	Pull current hashes from case telemetry or trusted feeds.
IP addresses	0 included	N/A	Enrich from DNS/proxy logs and current intel feeds.
Domains	0 included	N/A	Hunt known case domains; avoid stale blanket blocking.
URLs	0 included	N/A	Hunt download URLs from email, proxy, and browser history.

Indicator Class	Count	Confidence	Recommended Use
Host indicators	16 behavioral	High	Behavioral detection and triage.

7.2 Source Notes

Source	Contribution
Microsoft Security Blog	Delivery methods, capabilities, evasion, C2 evolution, process hollowing observations.
Microsoft On the Issues	Global disruption metrics and operational context.
FBI/CISA AA25-141B	Advisory framing, observed LummaC2 execution and C2 behavior.
MITRE ATT&CK	Software tracking and ATT&CK technique context.
Europol	Law enforcement disruption context.

7.3 File Hashes

Type	Indicator	Confidence	Handling
SHA256	Not included in this synthesis report.	N/A	Use case-specific EDR hashes and current threat feeds for exact-match sweeps.

7.4 Network Indicators

Type	Indicator	Confidence	Handling
Domain behavior	Newly registered or recently rotated domains contacted after script execution.	Medium	Hunt and enrich before blocking.
Domain behavior	Cloudflare-proxied domains contacted by suspicious child processes.	Medium	Require process context; Cloudflare alone is not suspicious.
C2 behavior	Repeated HTTPS POST attempts to multiple candidate C2 domains.	Medium	Correlate with process lineage and endpoint events.
Fallback behavior	Telegram or Steam profile content used as indirect C2 reference material.	Medium	Treat as suspicious only with malware execution context.

7.5 URL / Config Indicators

Type	Indicator	Confidence	Handling
Command parameter	Use of C2-related parameters such as act, ver, lid, uid, j, cid, hwid, or pid in suspicious POST traffic.	Medium	Version-specific; tune against normal web telemetry.

Type	Indicator	Confidence	Handling
Delivery URL	Download URLs reached from phishing, malvertising, fake CAPTCHA, or ClickFix lures.	Medium	Hunt proxy, DNS, browser history, and email click logs.

7.6 Host Indicators

Type	Indicator	Confidence	Notes
Process	Browser spawning powershell.exe, cmd.exe, mshta.exe, wscript.exe, cscript.exe, or curl.exe.	High	Stronger when followed by download and execution.
Registry	RunMRU entries containing PowerShell, mshta, curl, encoded content, or fake verification commands.	High	Strong ClickFix artifact.
Process	Unexpected msbuild.exe, regasm.exe, regsvcs.exe, or explorer.exe injection or hollowing.	Medium	Requires EDR memory/process telemetry.
File access	Non-browser process accessing browser cookie, password, or autofill databases.	High	High-value stealer behavior.
File access	Non-wallet process accessing wallet extension directories or wallet files.	High	High-value stealer behavior.
File access	Suspicious access to .ovpn, FTP client stores, email client data, Telegram data, .pdf, .docx, or .rtf files.	Medium	Context-dependent.
File path	Unsigned binaries from %TEMP%, %APPDATA%, %LOCALAPPDATA%, Downloads, or archive extraction paths.	Medium	Common staging locations.
Command line	-enc, FromBase64String, DownloadString, iwr, irm, curl, mshta, hidden window flags, or chained command interpreters.	Medium	Correlate with parent process and network.

7.7 IOC Usage Guidance

Exact hashes, domains, URLs, and IPs are best used for short-lived sweeps and scoping. Behavioral indicators are better for durable detections. Dual-use platforms such as GitHub, Telegram, Steam, Cloudflare, URL shorteners, Pastebin-like services, dynamic DNS, or geolocation APIs should never be treated as proof of compromise by themselves. Require process lineage, command line, download history, DNS/proxy context, and endpoint behavior.

8. MITRE ATT&CK Mapping

Tactic	Technique	Relevance
Initial Access	T1566.001 Spearphishing Attachment	Lumma campaigns use malicious attachments.
Initial Access	T1566.002 Spearphishing Link	Lumma campaigns use phishing URLs and cloned pages.
Execution	T1059 Command and Scripting Interpreter	PowerShell, JavaScript, and shell execution appear in delivery chains.
Execution	T1204 User Execution	Fake CAPTCHA, cracked software, and ClickFix flows rely on user execution.
Defense Evasion	T1027 Obfuscated Files or Information	Lumma binaries and scripts are heavily obfuscated.
Defense Evasion	T1036 Masquerading	Payloads may be embedded in spoofed or fake popular software.
Defense Evasion	T1055 Process Injection	Process injection and hollowing are reported.
Defense Evasion	T1140 Deobfuscate /Decode Files or Information	Samples decode strings and C2 domains at runtime.
Credential Access	T1555.003 Credentials from Web Browsers	Lumma steals browser passwords, cookies, and autofill data.
Collection	T1119 Automated Collection	Lumma collects files and application data.
Command and Control	T1071.001 Web Protocols	Lumma uses HTTP/HTTPS POST communications.
Exfiltration	TA0010 Exfiltration	Stolen data is sent to attacker-controlled infrastructure.

9. Detection Engineering

9.1 Detection Strategy

Prioritize detections around execution chains and credential-store access rather than single hashes. The highest-signal detections combine browser or user-click origin, script interpreter execution, suspicious command line, download behavior, credential store access, and outbound POST activity.

9.2 Sigma - Browser Spawned Script Interpreter

```

title: Browser Spawned Suspicious Script Interpreter Or Download Utility
id: 5f0c6e0a-55f7-4f41-9c1e-lumma-browser-script
status: experimental
description: Detects browser-originated execution of script interpreters and download utilities associated with infostealer delivery
references:
  - https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities/
logsource:
  category: process_creation

```

```
product: windows
detection:
  selection_parent:
    ParentImage|endswith:
      - '\chrome.exe'
      - '\msedge.exe'
      - '\firefox.exe'
      - '\brave.exe'
      - '\opera.exe'
  selection_child:
    Image|endswith:
      - '\powershell.exe'
      - '\pwsh.exe'
      - '\cmd.exe'
      - '\mshta.exe'
      - '\wscript.exe'
      - '\cscript.exe'
      - '\curl.exe'
  condition: selection_parent and selection_child
falsepositives:
  - Browser-based admin consoles that legitimately launch helper tools
  - Enterprise software portals
level: high
```

9.3 Sigma - Suspicious ClickFix Command Patterns

```
title: Suspicious ClickFix Style Verification Command
id: 88e6ff3a-a946-4b7b-b5ee-lumma-clickfix
status: experimental
description: Detects command patterns often seen when users paste fake verification commands into Windows Run or a shell.
logsource:
  category: process_creation
  product: windows
detection:
  selection_tools:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
      - '\mshta.exe'
      - '\wscript.exe'
      - '\cscript.exe'
  selection_cmd:
    CommandLine|contains:
      - 'FromBase64String'
      - '-enc '
      - 'DownloadString'
      - 'Invoke-WebRequest'
      - 'iwr '
      - 'irm '
      - 'mshta http'
      - 'curl http'
  condition: selection_tools and selection_cmd
falsepositives:
  - Administrative automation
  - Software deployment scripts
level: medium
```

9.4 Microsoft Defender XDR KQL - Browser To Script To Network

```
let Browsers = dynamic(["chrome.exe","msedge.exe","firefox.exe","brave.exe","opera.exe"]);
let ScriptTools = dynamic(["powershell.exe","pwsh.exe","cmd.exe","mshta.exe","wscript.exe","cscript.exe","curl.exe"]);
DeviceProcessEvents
| where InitiatingProcessFileName in~ (Browsers)
| where FileName in~ (ScriptTools)
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine, ReportId, DeviceId
| join kind=leftouter (
  DeviceNetworkEvents
  | where RemoteUrl !has_any ("microsoft.com","windows.com")
  | project DeviceId, NetworkTime=Timestamp, InitiatingProcessFileName, RemoteUrl, RemoteIP, RemotePort
) on DeviceId
| where isnull(NetworkTime) or NetworkTime between (Timestamp .. Timestamp + 10m)
```

9.5 Microsoft Defender XDR KQL - Browser Data Access By Non-Browser Process

```
let BrowserStores = dynamic(["\\Google\\Chrome\\User Data\\", "\\Microsoft\\Edge\\User Data\\", "\\Mozilla\\Firefox\\Profiles\\"
let SensitiveFiles = dynamic(["Login Data", "Cookies", "Web Data", "key4.db", "logins.json"]);
DeviceFileEvents
| where FolderPath has_any (BrowserStores)
| where FileName in~ (SensitiveFiles)
| where InitiatingProcessFileName !in~ ("chrome.exe", "msedge.exe", "firefox.exe", "brave.exe", "opera.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, InitiatingProcessCommandLine, FolderPath, FileName
```

9.6 Splunk SPL - Suspicious User-Writable Execution

```
index=edr sourcetype=process
(process_path="*\\AppData\\Local\\Temp\\" OR process_path="*\\AppData\\Roaming\\" OR process_path="*\\Downloads\\")
(process_name="*.exe" OR process_name="powershell.exe" OR process_name="mshta.exe")
| stats values(parent_process_name) values(process) values(dest) min(_time) max(_time) by user, process_name, process_path
```

9.7 YARA - Lumma-Like Stealer String Heuristic

```
rule MAL_Win_Lumma_Like_Stealer_Heuristic
{
  meta:
    description = "Heuristic for Lumma-like infostealer samples; requires tuning and validation"
    author = "Lost Boys Cyber"
    date = "2026-06-01"
    tlp = "CLEAR"
  strings:
    $s1 = "Login Data" ascii wide
    $s2 = "Cookies" ascii wide
    $s3 = "Local State" ascii wide
    $s4 = "logins.json" ascii wide
    $s5 = "key4.db" ascii wide
    $s6 = ".ovpn" ascii wide
    $s7 = "Telegram Desktop" ascii wide
    $w1 = "MetaMask" ascii wide
    $w2 = "Electrum" ascii wide
    $w3 = "Exodus" ascii wide
  condition:
    uint16(0) == 0x5A4D and 4 of ($s*) and 1 of ($w*)
}
```

9.8 Validation and Tuning Notes

The Sigma and KQL rules should be tuned against legitimate administrative scripts, software deployment systems, help desk tools, and browser helper applications. The YARA rule is intentionally heuristic and should not be used as a sole blocking control. Validate against known-good browser tooling, password managers, backup software, and forensic tools that may legitimately access browser stores.

10. Threat Hunting

10.1 Hunt Hypotheses

Hypothesis	Telemetry	Expected Evidence
A user executed a ClickFix-style Lumma delivery command.	Process, registry, clipboard/RunMRU if available, browser history.	Browser activity followed by RunMRU command and script interpreter execution.
Lumma accessed browser credential stores.	EDR file telemetry, process access, file open events.	Non-browser process reading Login Data, Cookies, Local State, logins.json, or key4.db.
Lumma exfiltrated stolen data over HTTPS.	Proxy, DNS, EDR network events.	Suspicious process POSTing to low-reputation or newly registered domains.

Hypothesis	Telemetry	Expected Evidence
A loader deployed Lumma as a secondary payload.	EDR process tree, file creation, network telemetry.	Initial downloader or loader followed by Lumma-like browser store access.
Stolen credentials were reused.	Identity provider, VPN, cloud audit, mailbox audit.	New sign-ins, impossible travel, new OAuth grants, mailbox forwarding, or suspicious MFA changes.

10.2 Endpoint Hunt

Start with endpoints that show browser-to-script interpreter chains, unsigned binaries in user-writable paths, or unusual access to browser stores. Pivot from parent process, command line, downloaded file path, hash, DNS domain, and user account.

10.3 Identity Hunt

For every confirmed Lumma endpoint, review:

- Interactive and non-interactive cloud sign-ins.
- MFA registration changes.
- OAuth consent grants.
- Mailbox forwarding and inbox rules.
- VPN logins.
- Privileged role activation.
- Password reset events.
- Sign-ins from unfamiliar ASN, geography, or device.

10.4 Network Hunt

Look for outbound HTTPS POST traffic from suspicious child processes, newly created executables, user-writable paths, script interpreters, or framework processes used in injection/hollowing chains. Treat Cloudflare, Telegram, Steam, and GitHub as context indicators only.

11. Triage and Incident Response

When Lumma is suspected or confirmed:

- 1 Isolate the host from the network.
- 2 Preserve volatile and forensic artifacts if the incident requires investigation.
- 3 Collect EDR timeline, process tree, command line, network connections, DNS, registry, browser access, file events, and downloaded files.
- 4 Identify the initial delivery vector and all staged payloads.
- 5 Remove malware only after collecting necessary evidence.

- 6 Reset passwords for accounts used on the infected host, prioritizing privileged, email, VPN, cloud, finance, and developer accounts.
- 7 Revoke active sessions, refresh tokens, remembered devices, and suspicious OAuth grants.
- 8 Review MFA methods for unauthorized additions or changes.
- 9 Review mailbox rules, forwarding, cloud sign-ins, VPN logs, and privileged account activity.
- 10 Check for follow-on malware, persistence, lateral movement, or remote access tooling.
- 11 Inspect cryptocurrency wallets and rotate or move wallet material if exposure is plausible.
- 12 Search the environment for matching execution chains, domains, hashes, and behaviors.
- 13 Notify affected users, business owners, legal, privacy, and compliance stakeholders according to severity.

12. Validation and Emulation

Validation should be performed in a controlled lab without executing live malware. Recommended approaches:

- Replay benign process telemetry that simulates browser-spawned script execution.
- Use Atomic Red Team or equivalent benign tests for T1059, T1204, T1555.003, and T1071.001 where appropriate.
- Create test files and mock browser-store paths to validate file access detections without exposing real credentials.
- Generate controlled HTTPS POST traffic from a test binary or script to validate process-plus-network correlation.
- Validate identity playbooks with tabletop exercises and test users, including token revocation and mailbox rule review.

Do not run live Lumma samples on production systems. Malware detonation should occur only in an isolated sandbox with appropriate legal authorization and containment.

13. Recommendations

Priority	Recommendation	Owner	Timeline
Critical	Treat confirmed Lumma infections as credential and session compromise events.	IR / IAM	Immediate
Critical	Revoke sessions, refresh tokens, remembered devices, and suspicious OAuth grants for affected users.	IAM / Cloud Security	Immediate
Critical	Reset passwords for accounts used on infected hosts, prioritizing privileged and remote access accounts.	IAM / Help Desk	Immediate

Priority	Recommendation	Owner	Timeline
High	Disable browser password storage where enterprise password managers are available.	Endpoint / IT	30 days
High	Deploy detections for browser-to-script execution and non-browser browser-store access.	Detection Engineering	14 days
High	Enable EDR block mode, tamper protection, network protection, and automated investigation.	Endpoint Security	14 days
High	Use attack surface reduction rules for obfuscated scripts, untrusted executable content, and credential theft behaviors.	Endpoint Security	30 days
High	Restrict execution from user-writable paths where operationally feasible.	Endpoint / IT	30-60 days
Medium	Add controls for newly registered domains and risky download categories.	Network Security	30 days
Medium	Monitor developer downloads from public repositories and package ecosystems.	AppSec / Security Engineering	60 days
Medium	Conduct user education focused on fake CAPTCHA, ClickFix, malvertising, and cracked software risks.	Security Awareness	30 days
Medium	Run quarterly tabletop exercises for infostealer-driven identity compromise.	IR / IAM / SOC	Quarterly

14. References and Refresh Notes

References

- Microsoft Security Blog, "Lumma Stealer: Breaking down the delivery techniques and capabilities of a prolific infostealer", 2025-05-21: <https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/>
- Microsoft On the Issues, "Disrupting Lumma Stealer: Microsoft leads global action against favored cybercrime tool", 2025-05-21: <https://blogs.microsoft.com/on-the-issues/2025/05/21/microsoft-leads-global-action-against-favored-cybercrime-tool/>
- FBI/CISA Joint Cybersecurity Advisory AA25-141B, "Threat Actors Deploy LummaC2 Malware to Exfiltrate Sensitive Data from Organizations", 2025-05-21: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141b>
- MITRE ATT&CK, "Lumma Stealer, Software S1213": <https://attack.mitre.org/software/S1213/>

- Europol, "Europol and Microsoft disrupt world's largest infostealer Lumma", 2025-05-21: <https://www.europol.europa.eu/media-press/newsroom/news/europol-and-microsoft-disrupt-world%E2%80%99s-largest-infostealer-lumma>

Refresh Notes

Refresh this report when any of the following occur:

- New Lumma infrastructure, hashes, or C2 protocol details are published by trusted sources.
- A new Lumma version changes delivery, encryption, C2, or plugin behavior.
- New law enforcement disruption or takedown information becomes available.
- Internal telemetry identifies case-specific IOCs or affiliate tradecraft.
- Detection false positives or false negatives require rule tuning.

TLP:CLEAR | Lost Boys Cyber | Lumma Stealer / LummaC2

Sample Addendum

Published: 2026-06-01 | TLP:CLEAR | Version: 1.1 Addendum | Author: Lost Boys Cyber

AI Generation: This addendum was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Scope

This addendum updates the Lumma Stealer / LummaC2 malware analysis report with static reverse-engineering findings from one submitted Windows executable sample. Analysis was static only; the binary was not executed.

2. Sample Metadata

Field	Value
Submitted archive	`48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54.7z`
Archive password	`infected`
Extracted filename	`48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54`
File type	PE32 executable for Microsoft Windows, Intel i386, GUI subsystem
File size	427,008 bytes
MD5	`69abcc261ae76d2b063672df06837966`
SHA1	`c4b5ca99073674df1cbf7615887b0a693879c188`
SHA256	`48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54`
Image base	`0x00400000`
Entry point	`0x00417950`
Reported compile timestamp	2023-12-24 16:12:52 UTC
Digital signature	Not signed
Static protections	NX enabled, stack canary present, ASLR-style PIC indicated, no relocations applied by loader metadata

3. Static Reverse-Engineering Findings

- The sample has only four PE sections: `.text`, `.rdata`, `.data`, and `.reloc`.
- The import table is deliberately small and imports only `KERNEL32.dll`, `GDI32.dll`, and `USER32.dll`.
- Imported APIs are limited to `CreateProcessW`, `ExitProcess`, screen-capture-related GDI/User32 routines, and cleanup helpers.
- `CreateProcessW` has static xrefs at `0x004212fc`, `0x004234e4`, and `0x00423542`.
- `BitBlt` has static xrefs at `0x004376b9` and `0x00437bd1`.
- `GetDIBits` has static xrefs at `0x0043836b` and `0x00438bae`.
- The entry point immediately pivots through an indirect jump via a pointer loaded from `.rdata` (`0x44bca4 -> 0x417972`), which is consistent with obfuscated or dispatcher-driven control flow.
- Static strings include ZIP handling errors, compression/decompression failure strings, and archive size/method validation text, indicating embedded archive-handling or collection-packaging logic.
- Static strings include `IEND`, consistent with PNG image output or image-processing code.
- Static strings include Windows version labels from Windows 2000 through Windows 11 and Windows Server releases through Server 2022, indicating host OS profiling logic.

- A hardcoded browser user-agent string is present: `Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.0.0 Safari/537.36`.
- Several high-entropy base64-like strings are present in `.rdata`; these should be treated as possible encoded configuration, keys, or encrypted strings until dynamically confirmed.
- No clear C2 domain, URL, IP address, wallet path, or campaign ID was recoverable through basic static strings.

4. Analyst Assessment

The sample characteristics are consistent with a protected Lumma-style infostealer payload rather than a simple commodity downloader. The small import table, indirect entry-point transfer, high-volume non-semantic strings, embedded archive error handling, browser user-agent, OS profiling strings, and screenshot API usage match capabilities described in public Lumma reporting: credential/session theft, host profiling, collection packaging, and optional screenshot or user-environment capture.

Attribution to Lumma remains medium confidence from static analysis alone because this sample addendum did not execute the binary, recover a decrypted configuration, or validate live C2 behavior. Confidence would increase with sandbox execution, memory capture after unpacking/string decryption, and recovered HTTP POST parameters or Lumma campaign identifiers.

5. IOC Handling

File Hashes

Type	Value	Confidence	Handling
SHA256	`48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54`	High	Block/quarantine exact file match
SHA1	`c4b5ca99073674df1cbf7615887b0a693879c188`	High	Block/quarantine exact file match
MD5	`69abcc261ae76d2b063672df06837966`	High	Use only for enrichment or legacy controls

Network Indicators

No network IOCs were statically recovered. Do not infer active C2 from the user-agent string alone.

Host Indicators

- PE32 GUI executable with SHA256 `48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54`.
- Import table containing `CreateProcessW` plus screen-capture API cluster: `GetDC`, `CreateCompatibleDC`, `CreateCompatibleBitmap`, `BitBlt`, `GetDIBits`, `GetDeviceCaps`, `GetObjectW`, `SelectObject`, `DeleteObject`, `DeleteDC`, `ReleaseDC`.
- Browser user-agent string: `Chrome/119.0.0.0 Safari/537.36`.

6. ATT&CK Mapping

Technique	Mapping	Rationale
T1059 / Command and Scripting Interpreter	Possible	`CreateProcessW` xrefs may support child-process launch; command content was not statically recovered.
T1113 / Screen Capture	Likely	GDI/User32 screen-capture imports and xrefs to `BitBlt` and `GetDIBits`.
T1082 / System Information Discovery	Likely	Windows version strings indicate OS profiling.
T1027 / Obfuscated Files or Information	Likely	Small import table, indirect entry transfer, and high-entropy strings.

Technique	Mapping	Rationale
T1005 / Data from Local System	Possible	Archive/compression strings suggest collection packaging, but file targeting was not statically recovered.
T1041 / Exfiltration Over C2 Channel	Possible	User-agent string suggests HTTP client behavior, but C2 and POST logic were not recovered in this pass.

7. Detection Content

Sigma - Suspicious PE With Screen Capture Cluster and Sparse Imports

```

title: Suspicious Windows PE With Sparse Imports And Screen Capture API Cluster
id: 4ca7cf80-9e1a-4e7e-9230-48cbeb1b1ca0
status: experimental
description: Detects files resembling the analyzed Lumma-style sample based on a sparse import table and GDI/User32 screen capture
author: Lost Boys Cyber
date: 2026-06-01
references:
  - https://attack.mitre.org/techniques/T1113/
  - https://attack.mitre.org/software/S1213/
tags:
  - attack.collection
  - attack.t1113
  - attack.defense-evasion
  - attack.t1027
logsource:
  product: windows
  category: file_event
detection:
  selection_pe:
    TargetFilename|endswith:
      - ".exe"
  selection_strings:
    ImageLoaded|contains|all:
      - "GDI32.dll"
      - "USER32.dll"
  condition: selection_pe and selection_strings
falsepositives:
  - Legitimate screenshot utilities and remote support tools.
  - This rule requires enrichment with PE import metadata; tune against known enterprise software.
level: medium

```

YARA - Lumma-Style Sample 48cbeb Static Traits

```

rule MAL_Win_LummaStyle_48cbeb_Static_Addendum {
  meta:
    description = "Static traits from submitted Lumma-style PE32 sample"
    author = "Lost Boys Cyber"
    date = "2026-06-01"
    sha256 = "48cbeb1b1ca0a7b3a9f6ac56273fbaf85e78c534e26fb2bca1152ecd7542af54"
    tlp = "CLEAR"
  strings:
    $api1 = "CreateProcessW" ascii
    $api2 = "BitBlt" ascii
    $api3 = "GetDIBits" ascii
    $api4 = "CreateCompatibleBitmap" ascii
    $ua = "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36" wide
    $zip1 = "not a ZIP archive" ascii
    $zip2 = "unsupported encryption" ascii
    $zip3 = "CRC-32 check failed" ascii
    $os1 = "Windows 11" ascii
    $os2 = "Windows Server 2022" ascii
    $png = "IEND" ascii
  condition:
    uint16(0) == 0x5a4d and filesize < 700KB and
    all of ($api*) and $ua and
    2 of ($zip*) and
    1 of ($os*) and $png
}

```

8. Recommended Follow-Up

- Run the sample in an isolated malware sandbox with no shared clipboard, no host-mounted user profile, and controlled DNS/HTTP capture.
- Collect memory after initial unpacking or string decryption and rerun strings/YARA against the memory image.
- Monitor child process creation from the sample hash and capture full command lines for `CreateProcessW` behavior.
- Capture HTTP requests and POST bodies if executed; look for Lumma protocol parameters such as `ver`, `uid`, `cid`, and `hwid`.
- Treat any confirmed endpoint hit as an identity compromise event: rotate browser-stored credentials, revoke sessions, reset VPN and cloud tokens, and review mailbox/cloud access logs.

9. References

- Microsoft Security Blog, "Lumma Stealer: Breaking down the delivery techniques and capabilities of a prolific infostealer", 2025-05-21.
- MITRE ATT&CK, Lumma Stealer software entry S1213.
- Static analysis performed locally with `file`, `7z`, `rabin2`, `radare2`, `strings`, `sha256sum`, `sha1sum`, and `md5sum`.